

**Área de Conocimiento de Tecnología de la Información y Comunicación**

**Auditoría de Sistemas**

COBIT. Dominio de Planificación y Organización ACTIVIDADES PRACTICAS  
IMPLEMENTACION DE COBIT

**Elaborado por:**

Br. Gerson Antonio  
Valdivia

Br. Haxell Antonio  
Trejos Rodríguez

Br. Alison Michelle  
Navarro Goussen

Br. Stephanie Lucía  
Mora Chávez

Br. Arleth del Rosario  
Velásquez Gómez

**Docente:**

Msc. Leonel Antonio Martínez Zuniga

23 de mayo, 2026  
Managua, Nicaragua

**I. ACTIVIDAD 1.** Considerando el dominio Entregar, Dar Servicio y Soporte (DSS): Involucra la entrega en sí de los servicios requeridos, incluyendo la prestación del servicio, la administración de la seguridad y de la continuidad, el soporte a los usuarios del servicio, la administración de los datos y de las instalaciones operativas. Su objetivo es lograr que los servicios de TI se entreguen de acuerdo con las prioridades del negocio, la optimización de costos, asegurar que la fuerza de trabajo utilice los sistemas de modo productivo y seguro, implantar de forma correcta la confidencialidad, la integridad y la disponibilidad.

**a. Elabore o prepare un instrumento de recopilación de datos o información**

| Proceso COBIT 2019                       | Pregunta de Evaluación                                                                                                                                          | Respuesta Esperada / Evidencia Requerida                                                               |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| <b>DSS01 - Gestión de Operaciones</b>    | ¿Existe un programa formal y documentado de mantenimiento preventivo para el hardware de red (Switches, Router ISP) y las unidades de respaldo eléctrico (UPS)? | Documento de cronograma de mantenimiento, bitácoras de limpieza o reportes de estado de baterías.      |
| <b>DSS01 - Gestión de Operaciones</b>    | ¿Se monitorea el entorno físico (temperatura, humedad, energía) donde operan los equipos centrales de conmutación?                                              | Registros de control ambiental, termómetros en sala, supresores de picos industriales instalados.      |
| <b>DSS02 - Gestión de Incidentes</b>     | ¿Cómo se reportan y registran las interrupciones de conectividad o fallos en las estaciones de trabajo por parte de los usuarios?                               | Sistema de <i>tickets</i> de mesa de ayuda, correos electrónicos estandarizados o formatos de reporte. |
| <b>DSS03 - Gestión de Problemas</b>      | Cuando ocurren caídas recurrentes de red (ej. lentitud al usar SISNIVEN), ¿se realiza un análisis para encontrar la causa raíz o solo se reinician los equipos? | Documentos de análisis de causa raíz (ej. 5 Porqués), base de datos de errores conocidos (KDB).        |
| <b>DSS04 - Gestión de la Continuidad</b> | ¿Se cuenta con un Plan de Recuperación ante Desastres (DRP) en caso de daño total del switch                                                                    | Documento DRP aprobado, inventario de equipos de respaldo (repuesto en frío), RTO y RPO                |

|                                     |                                                                                                                                                                                                            |                                                                                                                |
|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
|                                     | principal o pérdida del enlace WAN?                                                                                                                                                                        | definidos.                                                                                                     |
| <b>DSS05 - Gestión de Seguridad</b> | ¿Existe segmentación lógica (VLANs) o reglas de <i>Firewall</i> local para aislar las estaciones de trabajo de áreas críticas (Epidemiología) del resto de la red?                                         | Configuraciones extraídas de switches administrables, diagramas lógicos, reglas de <i>Firewall</i> en Windows. |
| <b>DSS05 - Gestión de Seguridad</b> | ¿Se aplican controles restrictivos en las terminales (bloqueo de puertos USB, políticas de contraseñas, <i>Deep Freeze</i> ) para evitar desconfiguraciones intencionales o infección por <i>malware</i> ? | Políticas de grupo activas, validación de congelamiento de estado en PCs de laboratorio/áreas comunes.         |

**b. Realice un avance de la auditoria utilizando COBIT, en la empresa donde está realizando el proyecto**

La aplicación de las pruebas técnicas y el instrumento de recopilación de datos arrojaron los siguientes hallazgos alineados a los procesos del dominio DSS:

**DSS01 – Gestión de Operaciones:**

- **Condiciones Ambientales:** El núcleo de red opera a temperaturas sostenidas superiores a los 32°C sobre un escritorio de madera, sin ventilación activa ni acondicionamiento de energía de grado industrial, acelerando la degradación del hardware.
- **Capacidad y Rendimiento:** Existe un estrangulamiento crónico del rendimiento. Los switches Fast Ethernet obsoletos limitan la velocidad a 100 Mbps, desaprovechando las tarjetas Gigabit de las estaciones de trabajo y ralentizando la transmisión de datos al MINSA Central.

**DSS02 – Gestión de Solicitudes e Incidentes / DSS03 – Gestión de Problemas:**

- **Soporte Reactivo:** No existe un procedimiento formal ni un sistema de *tickets* para registrar fallas de conectividad. Los incidentes se reportan de manera verbal y se resuelven temporalmente sin realizar análisis de causa raíz. La falta

de un responsable de TI formalmente designado agrava la cronificación de los problemas.

#### **DSS04 – Gestión de la Continuidad:**

- **Ausencia de DRP:** El SILAIS no cuenta con un Plan de Continuidad de Negocio o Recuperación ante Desastres. Un fallo catastrófico en el único switch principal de la Dirección provocaría una parálisis total de la red por tiempo indefinido, interrumpiendo el reporte epidemiológico del SISNIVEN.

#### **DSS05 – Gestión de Servicios de Seguridad:**

- **Red Plana y Fugas:** La infraestructura opera sin segmentación lógica (ausencia de VLANs). Áreas críticas como el Banco Biológico y Epidemiología comparten el mismo dominio de difusión que las áreas comunes, lo que facilita el movimiento lateral de *malware*. Además, existen conexiones privadas no controladas en Transporte y Sindicato, operando como *bypass* a la seguridad corporativa.

#### **c. Presente un resumen del informe preliminar, hasta el lugar donde lo tiene actualmente.**

La auditoría de infraestructura de redes y hardware en el SILAIS – Sede Masaya revela brechas de nivel crítico al contrastar la situación actual con los marcos ISO/IEC 27001, COBIT 2019 (Dominio DSS) y la normativa nacional SISNIVEN. La institución opera bajo un nivel de madurez tecnológica deficiente (Nivel 0-1 en COBIT), caracterizado por hardware obsoleto, cableado estructurado carente de canaletas de protección y rosetas (incumpliendo ANSI/TIA-568-C y 569-C), y condiciones ambientales adversas que incrementan el riesgo de daño físico a los equipos centrales.

En el ámbito de la seguridad, la topología de "red plana" y el uso de switches Fast Ethernet no administrables imposibilitan la segmentación de los datos. Esta condición, sumada a la alta dependencia de redes WiFi con cifrado no verificado en 14 áreas de trabajo y la proliferación de conexiones privadas a Internet, expone información altamente sensible de pacientes y personal, contraviniendo los lineamientos de la Ley 921 de Protección de Datos Personales.

**Conclusiones y Plan de Mejora Estratégico** La gestión tecnológica en la sede es puramente reactiva, careciendo de mantenimientos preventivos programados, sistemas de gestión de incidentes y un Plan de Continuidad de Negocio (DRP). Para mitigar el riesgo extremo de parálisis en la transmisión de datos de salud pública, se propone un plan de acción dividido en fases:

1. **A corto plazo (0-30 días):** Institucionalizar la matriz de riesgos generada, auditar las contraseñas de la red inalámbrica y designar un responsable único que canalice los reportes de fallas mediante un sistema de *tickets* gratuito.
2. **A mediano plazo (30-60 días):** Ejecutar la renovación del núcleo de red reemplazando los switches Fast Ethernet por switches Gigabit administrables para configurar VLANs que aislen el tráfico crítico. A la par, instalar un gabinete (Rack) de pared y estandarizar el cableado utilizando canaletas y *patch panels*.
3. **A largo plazo (2-6 meses):** Implementar puntos de red cableados para reducir la dependencia del WiFi en áreas críticas, establecer monitoreo continuo de ancho de banda e instaurar cronogramas estrictos de mantenimiento preventivo para el hardware y los sistemas UPS.

**II. ACTIVIDAD 2.** Esta actividad esta orientada a los dos grupos que ya trabajaron con el primer dominio y por lo tanto están en proceso de aplicación de uno de los otros. Se orienta aplicar Dominio de Planificación y Organización, en caso que no lo haya usado en el corte anterior. Considerando que ya tiene un avance y conocimiento sobre la aplicación de este marco de trabajo, realice las siguientes tareas:

**a. Seleccione un dominio de COBIT y presente un resumen de una página.**

El dominio Alinear, Planificar y Organizar (APO) constituye la columna vertebral estratégica dentro del marco de referencia COBIT 2019. Su propósito fundamental es establecer la dirección táctica de las Tecnologías de la Información (TI) y asegurar que estas se integren de manera óptima y coherente con los objetivos generales del negocio o institución. En esencia, este dominio actúa como el puente traductor entre las directrices de alto nivel establecidas por el gobierno corporativo (dominio EDM - Evaluar, Dirigir y Monitorizar) y la ejecución operativa diaria. Su enfoque principal es responder a preguntas gerenciales críticas: ¿Están las TI y el negocio alineados estratégicamente? ¿Se están planificando adecuadamente los recursos para maximizar el valor? y ¿Se están identificando y mitigando los riesgos antes de que impacten la operación?

A diferencia de los dominios netamente operativos como DSS (Entregar, Dar Servicio y Soporte), que se enfocan en el "hacer" diario y la resolución inmediata de problemas, APO se centra en el "diseño", la "planificación" y la "gobernanza" a nivel gerencial. Este dominio es extenso y riguroso, abarcando 14 procesos esenciales que pueden agruparse en tres grandes pilares de gestión:

### 1. Estrategia, Arquitectura e Innovación (APO01 - APO04):

Este primer bloque sienta las bases operativas. Comienza con la definición del marco de gestión de TI (APO01) y la formulación de la estrategia tecnológica (APO02). Incluye la gestión de la arquitectura empresarial (APO03), que es vital para trazar cómo la tecnología soporta los procesos críticos de la entidad, y fomenta la innovación (APO04) para mantener a la institución actualizada frente a los avances tecnológicos y las nuevas exigencias del entorno.

### 2. Gestión de Inversiones, Recursos y Relaciones (APO05 - APO10):

En este pilar, el enfoque se desplaza hacia la viabilidad y el soporte humano y financiero. Abarca la optimización del portafolio de servicios (APO05) y la gestión rigurosa del presupuesto y los costos de TI (APO06), garantizando que las inversiones tecnológicas estén justificadas y fondeadas. Asimismo, aborda la gestión de los recursos humanos (APO07), asegurando que el personal técnico posea las competencias necesarias, y regula la gestión de las relaciones institucionales (APO08), los acuerdos de nivel de servicio (APO09) y la gestión de proveedores externos (APO10).

### 3. Calidad, Riesgo, Seguridad y Datos (APO11 - APO14):

El último bloque se enfoca en la protección y mejora continua de los activos. Define los estándares de gestión de la calidad (APO11) y establece la metodología para la gestión del riesgo (APO12), un proceso ineludible para identificar vulnerabilidades antes de que se materialicen. Finalmente, aborda la gestión integral de la seguridad de la información (APO13) y la administración de los datos (APO14), asegurando la confidencialidad, integridad y disponibilidad de la información procesada.

En el contexto de una auditoría de sistemas, evaluar el dominio APO es un paso crítico y revelador para identificar deficiencias estructurales profundas. Las auditorías tradicionales a menudo se limitan a señalar errores físicos o lógicos inmediatos; sin embargo, un fallo constante en la infraestructura de red (un problema observable en el dominio DSS) casi siempre tiene su causa raíz en una debilidad del dominio APO. Por ejemplo, el uso de equipos de conmutación obsoletos suele ser el síntoma de una nula planificación presupuestaria para la renovación tecnológica (APO06), mientras que la falta de documentación y el desorden en el cableado son consecuencias directas de la ausencia de personal capacitado y roles formalmente asignados a TI (APO07).

En conclusión, la implementación y madurez de los procesos del dominio APO garantizan que las inversiones y esfuerzos en tecnología no sean acciones aisladas o puramente reactivas. Por el contrario, transforman la TI en una iniciativa planificada que habilita los procesos críticos de la organización, asegurando la calidad del servicio, la optimización eficiente del presupuesto estatal o corporativo, y una postura proactiva frente a las amenazas de ciberseguridad a mediano y largo plazo.

**b. Prepare al menos 2 herramientas, métodos o técnicas, para recopilar la información o contar con el insumo requerido para la auditoria.**

### **HERRAMIENTA 1: CUESTIONARIO DE ENTREVISTA ESTRUCTURADA A LA ALTA DIRECCIÓN**

**Objetivo:** Evaluar el nivel de madurez y alineación estratégica de las TI con los objetivos del SILAIS, enfocándose en los procesos APO01 (Marco de TI), APO06 (Presupuesto) y APO07 (Recursos Humanos).

**Dirigido a:** Dirección General / Responsable de Planificación del SILAIS Sede Masaya.

**Entrevistador:** Equipo Auditor UNI.

**Fecha de Aplicación:** Mayo, 2026.

| ID   | Pregunta Estructurada (Proceso COBIT)                                                                                                                                                                               | Respuesta / Evidencia Recopilada del Entrevistado                                                                                                                                                                                                                        |
|------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| P-01 | (APO01) ¿Existe un documento formal de estrategia tecnológica o plan operativo de TI alineado a los objetivos de salud del SILAIS (ej. asegurar la transmisión ininterrumpida del SISNIVEN) para los próximos años? | <b>Respuesta:</b> No existe un plan estratégico de TI formalmente documentado. Las directrices tecnológicas provienen esporádicamente del MINSA Central, pero a nivel local la gestión se enfoca en mantener la operatividad diaria (reactiva). No hay un plan a 3 años. |

|             |                                                                                                                                                                                                                 |                                                                                                                                                                                                                                                                        |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P-02</b> | <b>(APO01)</b> ¿Cómo se toman las decisiones de inversión en tecnología o cambios en la red dentro de la institución? ¿Existe un comité para esto?                                                              | <b>Respuesta:</b> No existe un comité de TI. Las decisiones de compra o reparación se toman a nivel de Dirección Administrativa únicamente cuando un equipo falla de forma crítica (ej. se quema un switch o una PC), previa solicitud del área afectada.              |
| <b>P-03</b> | <b>(APO06)</b> ¿Dentro del Plan Operativo Anual (POA) del SILAIS Masaya, existe una partida presupuestaria específica y asignada para el mantenimiento preventivo y la renovación de la infraestructura de red? | <b>Respuesta:</b> No existe una partida exclusiva para renovación de red. Los gastos tecnológicos se asumen desde un fondo general de "mantenimiento de equipos y oficina". Por ende, no hay presupuesto aprobado para reemplazar los switches Fast Ethernet actuales. |
| <b>P-04</b> | <b>(APO06)</b> En caso de un fallo catastrófico (ej. se daña el Router ISP o el Switch Principal por una fluctuación eléctrica), ¿cómo se aprueban los fondos de emergencia para restablecer el servicio?       | <b>Respuesta:</b> Se debe solicitar una reasignación de fondos de emergencia a Administración o elevar la solicitud al MINSA Central. Este proceso burocrático puede tardar de varios días a semanas, tiempo durante el cual la red estaría inoperativa.               |
| <b>P-05</b> | <b>(APO07)</b> ¿Existe un cargo formal en el organigrama (con manual de funciones) dedicado exclusivamente a la gestión de las telecomunicaciones, soporte técnico y seguridad de la red?                       | <b>Respuesta:</b> No existe el cargo formal en el organigrama departamental. Las labores de soporte se delegan empíricamente a personal administrativo o de estadística que tiene "conocimientos básicos" de informática, sumado a sus labores diarias.                |



|             |                                                                                                                                                                                                     |                                                                                                                                                                                                                              |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>P-06</b> | <b>(APO07)</b> ¿Se imparten capacitaciones periódicas al personal médico y administrativo sobre el uso seguro de la red institucional, riesgos de redes WiFi y protección de datos epidemiológicos? | <b>Respuesta:</b> No se realizan capacitaciones formales en ciberseguridad o uso de redes. El personal se capacita únicamente en el llenado de datos médicos en el sistema SISNIVEN, pero no en seguridad de la información. |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## HERRAMIENTA 2: LISTA DE VERIFICACIÓN Y REVISIÓN DOCUMENTAL (CHECKLIST)

**Objetivo:** Verificar la existencia, vigencia y calidad de la documentación formal que respalda la gobernanza de TI, la gestión de riesgos (APO12) y la seguridad de la información (APO13) en el SILAIS Masaya. **Dirigido a:** Área Administrativa / Personal de Soporte Empírico. **Fecha de Revisión:** Mayo, 2026.

| ID Doc.     | Documento / Insumo Solicitado                                                                 | Proceso COBIT | ¿Es Requerido? | ¿Existe?          | Estado de la Evidencia / Observaciones del Auditor                                                                                                                        |
|-------------|-----------------------------------------------------------------------------------------------|---------------|----------------|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>D-01</b> | <b>Inventario de Activos de Red</b> (Físico y Lógico) con valorización y estado de vida útil. | APO01 / APO06 | <b>SÍ</b>      | <b>INCOMPLETO</b> | Existe una lista básica de bienes del Estado en bodega, pero no detalla parámetros técnicos de red (IPs, MAC, ciclo de vida de los switches TP-Link o del Router Huawei). |

|             |                                                                                                     |               |           |           |                                                                                                                                                                                     |
|-------------|-----------------------------------------------------------------------------------------------------|---------------|-----------|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>D-02</b> | <b>Diagrama de Arquitectura de Red</b> (Topología lógica, física y de direccionamiento IP).         | APO01 / APO13 | <b>SÍ</b> | <b>NO</b> | No hay mapas topológicos. El conocimiento de qué cable va a qué área funcional (Sindicato, Banco Biológico, etc.) reside empíricamente en el personal que lo instaló originalmente. |
| <b>D-03</b> | <b>Matriz de Riesgos Tecnológicos y Seguridad de la Información</b> aprobada por la dirección.      | APO12         | <b>SÍ</b> | <b>NO</b> | Ausencia total de identificación de riesgos. Riesgos como la red plana o la obsolescencia de equipos operan a ciegas sin planes de mitigación aprobados.                            |
| <b>D-04</b> | <b>Políticas de Seguridad de la Información y Uso Aceptable de la Red</b> firmadas por el personal. | APO13         | <b>SÍ</b> | <b>NO</b> | No existen normativas que prohíban el uso de USBs no autorizadas, ni reglas para evitar la fuga de datos del SISNIVEN a través de las conexiones privadas no monitoreadas.          |

|             |                                                                                                     |               |           |           |                                                                                                                                                                                       |
|-------------|-----------------------------------------------------------------------------------------------------|---------------|-----------|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>D-05</b> | <b>Procedimiento de Gestión y Cambio de Contraseñas</b><br>(Equipos de red, Puntos de Acceso WiFi). | APO13         | <b>SÍ</b> | <b>NO</b> | Las contraseñas de las redes WiFi de las áreas críticas (Estadística, Enfermería) son estáticas, de dominio general y no se documentan actualizaciones periódicas.                    |
| <b>D-06</b> | <b>Plan de Continuidad de Negocio (BCP) y Recuperación ante Desastres (DRP).</b>                    | APO12 / DSS04 | <b>SÍ</b> | <b>NO</b> | Si el SILAIS queda incomunicado por fallo eléctrico o daño del switch, no existe una guía documentada paso a paso sobre cómo operar el SISNIVEN de manera alterna o restaurar la red. |

**c. Presente un informe del avance de la aplicación del dominio seleccionado, en el caso del proyecto.**

La aplicación de las herramientas de recopilación de datos para el dominio APO en el SILAIS – Sede Masaya ha permitido identificar hallazgos críticos a nivel estratégico y organizacional, los cuales explican muchas de las deficiencias operativas encontradas en el dominio DSS.

**Avance de Hallazgos por Proceso APO:**

- **APO01 - Gestionar el marco de gestión de TI:**
  - *Hallazgo:* Se evidenció una carencia total de un marco formal de gestión de TI. La administración de la tecnología se realiza de manera empírica, sin políticas documentadas ni métricas de desempeño alineadas a los objetivos de salud pública.
- **APO06 - Gestionar el presupuesto y los costes:**
  - *Hallazgo:* La obsolescencia de los Switches Fast Ethernet (limitados a 100 Mbps) y el cableado UTP expuesto derivan directamente de la falta de un presupuesto anual asignado y gestionado para TI. No existe un plan de inversión o renovación tecnológica (CAPEX/OPEX) documentado para la red de comunicaciones.
- **APO07 - Gestionar los recursos humanos:**
  - *Hallazgo:* El organigrama del SILAIS no contempla un rol formal de "Administrador de Red" o "Responsable de Seguridad de la Información". Las tareas de soporte se asignan de manera informal a personal que no posee el tiempo ni la capacitación especializada necesaria, lo que genera una cultura de gestión puramente reactiva.
- **APO12 - Gestionar el riesgo:**
  - *Hallazgo:* La Alta Dirección no ha establecido un proceso para identificar, analizar ni mitigar los riesgos de TI. Riesgos críticos, como el colapso de la red plana ante un ataque de *ransomware* o fallos por condiciones ambientales, operan como "riesgos no gestionados" u ocultos, ya que no existe una Matriz de Riesgos aprobada.

**Conclusión Preliminar del Avance APO:** La evaluación inicial del dominio APO indica un nivel de madurez cercano a 0 (Incompleto) en los procesos estratégicos de TI. Las deficiencias operativas (como la falta de segmentación VLAN o los equipos sobrecalentados encontrados en el dominio DSS) son síntomas de una causa raíz mayor: **la falta de gobernanza y planificación presupuestaria en la Alta Dirección.** Para que las recomendaciones técnicas (como comprar nuevos switches o instalar canaletas) sean sostenibles, el SILAIS debe formalizar el rol de TI y establecer procesos presupuestarios y de gestión de riesgos alineados a COBIT APO.